

Access Control Policy

Parent: INFOSEC_POLICY.md **Owner:** Matt Fellows — matt@tangiblevalue.com **Effective date:** 2026-05-06 **Review cadence:** quarterly self-review of all account inventories below; full policy review annually.

1. Principles

- **Least privilege:** each system, account, or token has only the permissions it requires for its purpose.
- **Single owner:** every system in the asset inventory has exactly one human owner (the Owner).
- **Fail closed:** where access is gated by configuration (e.g., the registration allow-list), the absence of configuration denies access rather than grants it.

2. Roles

The system has two effective roles:

Role	Holder	Permissions
Owner	Matt Fellows	Full read/write to every record in the system; admin on all infrastructure; only role permitted to register an account.
Demo	demo@example.com (development only)	Login to a sandboxed demo account; cannot read or modify Owner data. Disabled in production unless ALLOW_DEMO_LOGIN=true.

There is no “user” tier in the public sense — registration is gated by allow-list (see §4 below).

3. Application-level Access Controls

Control	Mechanism	Reference
First-factor auth	Email + password; bcryptjs with salt rounds = 10	backend/routes/auth.js
Second-factor auth	WebAuthn passkey (FIDO2). Once the Owner registers a passkey at /security, every subsequent login requires it before a JWT is issued. Phishing-resistant.	backend/services/passkeyService.js, backend/routes/auth.js (passkey/* endpoints), src/pages/Login.tsx, src/pages/Security.tsx
Session	JWT signed with JWT_SECRET, HS256, 7-day expiry; stored client-side in localStorage; sent via Authorization: Bearer header by an axios interceptor wired in AuthContext.	backend/routes/auth.js, src/contexts/AuthContext.tsx

Control	Mechanism	Reference
Per-request authorization	optionalAuth middleware on data routes. In production, fails closed (HTTP 401) when no valid token is present. Demo fallback is preserved only in development.	backend/middleware/auth.js
Route protection (frontend)	<RequireAuth> wrapper redirects unauthenticated visitors to /login before any protected page renders.	src/components/RequireAuth.tsx, src/App.tsx
HTTP hardening	helmet (default header set), express-rate-limit (1000 req / 15 min / IP), CORS allow-list via CORS_ORIGINS	backend/server.js
Registration restriction	REGISTRATION_ALLOWLIST env var; empty in prod = registration disabled	backend/routes/auth.js → isAllowedToRegister
Demo route restriction	Returns 404 in production unless ALLOW_DEMO_LOGIN=true	backend/routes/auth.js

4. Non-human Authentication

Caller	Credential	Stored	Notes
Vercel Cron → /api/internal/sync-all	CRON_SECRET bearer token	Vercel encrypted env	Cron runs every 6 hours per vercel.json.
App → Plaid API	PLAID_CLIENT_ID + PLAID_SECRET	Vercel encrypted env	Standard Plaid client credentials.
App → Firestore	Service account JSON (FIREBASE_SERVICE_ACCOUNT)	Vercel encrypted env	Limited to the wealth-navigator Firebase project.
App-layer encryption	ENCRYPTION_KEY (32-byte hex) for AES-256-CBC of Plaid access tokens	Vercel encrypted env	See ENCRYPTION.md.

5. Infrastructure Account Inventory

This is the list of every external service that holds credentials capable of accessing wealth-navigator data, code, or secrets. Reviewed quarterly.

MFA status verified 2026-05-06.

System	Purpose	Account holder	MFA status	Notes
Email (matt@tangiblevalley.com, Google Workspace)	Account recovery for everything below	Matt Fellows	☐ Phishing-resistant (passkey / hardware key)	Compromise of email = compromise of everything; this is the highest-priority account and is locked down accordingly.
1Password	Storage of credentials for the rest of the systems	Matt Fellows	☐ Phishing-resistant (hardware key)	Master password + hardware-key second factor. Secret Key stored physically off-device.
Plaid Dashboard	API keys, webhook config, team membership	Matt Fellows	⚠ Non-phishing-resistant (TOTP authenticator app)	Email + password login. Upgraded from SMS to TOTP on 2026-05-06. Open follow-up: register a hardware key/passkey when Plaid supports it; remove SMS as backup.
Vercel	Production hosting + env vars (JWT_SECRET, ENCRYPTION_KEY, PLAID_SECRET, FIRE-BASE_SERVICE_ACCOUNT, CRON_SECRET)	Matt Fellows (via Google SSO)	☐ Phishing-resistant (inherited from Google)	Account verified to use “Sign in with Google” — security inherits the email account above.
Firebase / Google Cloud	Firestore database, IAM service account	Matt Fellows (Google account)	☐ Phishing-resistant (inherited from Google)	Project membership: only the Owner. Service accounts: exactly one (the one whose JSON is in FIRE-BASE_SERVICE_ACCOUNT). Verified 2026-05-06.

System	Purpose	Account holder	MFA status	Notes
GitHub (github.com/mmfe1/public- navigator)	Source code (public repo). Write access can ship a backdoor that Vercel auto-deploys.	Matt Fellows	⚠ Non-phishing- resistant (TOTP authenticator app)	Public repo; no secrets ever committed. PAT inventory clean (1 expired/unused token to delete). Fine-grained PATs: none. SSH keys: none. Open follow-up: upgrade MFA to passkey/hardware key (~30s in Settings → Password and authentication); audit Authorized OAuth Apps and Installed GitHub Apps.
Developer machine (Mac)	Source code, local .env, secrets in keychain	Matt Fellows	☑ FileVault on (AES-128 XTS full-disk encryption); login password + Touch ID	macOS auto-update enabled.

Federation: a mix of identity providers is in use across the systems above (some Google SSO, some GitHub OAuth, some standalone username/password). Centralized IAM is **not** in place — answered honestly on the Plaid questionnaire.

6. Periodic Access Review

Every quarter (calendar reminder set), the Owner verifies:

- The rows in §5 still reflect reality (no extra services were added without documenting them here).
- No collaborators have been added to GitHub, Vercel, or Firebase.
- The Plaid Dashboard team list contains only the Owner.
- No additional users exist in the Firestore users collection (SELECT * FROM users WHERE email != 'matt@tangiblevalue.com' AND email != 'demo@example.com' should be empty in production).
- The REGISTRATION_ALLOWLIST env var still contains only the Owner's email.
- Vercel project settings → Environment Variables list matches the inventory above (no orphaned secrets).

Each review is logged with the date and reviewer in ACCESS_REVIEW_LOG.md (created on first review).

7. Known Gaps

These are real gaps that are tracked rather than glossed over.

Gap	Risk	Status
Plaid /api/plaid/webhook endpoint does not verify the Plaid-Verification JWT header.	An attacker who learns the webhook URL and a valid item_id could inject fake transaction/holdings data, polluting the user's records. Plaid sends this signature with every webhook.	Closed (2026-05-06) — verification implemented in backend/services/plaidWebhookVerifier.js and gated in backend/routes/plaid.js → POST /webhook. Unverified requests are rejected with HTTP 401 and logged. Verification covers ES256 signature, body SHA-256 hash, and 5-minute freshness window. Reference: Plaid webhook verification docs .
MFA status of infrastructure accounts (§5) is "to verify" rather than confirmed.	If an account password is leaked and MFA is off, attacker can log in with just the password.	Closed (2026-05-06) — full inventory verified; see §5. Two non-phishing-resistant accounts (Plaid Dashboard, GitHub) tracked as their own follow-ups below.
Plaid Dashboard MFA is TOTP (non-phishing-resistant).	A real-time phishing relay attack could capture and replay the TOTP code, granting access to the Production secret.	Open — register hardware key/passkey when Plaid supports it; remove SMS as backup factor. SLA: review at next quarterly access review (§6).
GitHub MFA is TOTP (non-phishing-resistant); Authorized OAuth Apps and Installed GitHub Apps not yet audited.	A real-time phishing relay could push a malicious commit, which Vercel auto-deploys. Stale OAuth grants give third parties standing access to push code.	Open — upgrade MFA to passkey/hardware key + complete OAuth/Apps audit. SLA: 7 days.
No automated alerting when a new user is added to Firestore users.	A misconfiguration or bypass of the allow-list would not surface immediately.	Accepted residual risk. Quarterly review (§6) catches it.

8. References

- INFOSEC_POLICY.md — parent policy
- backend/routes/auth.js — registration allow-list, JWT, demo gate
- backend/middleware/auth.js — authentication middleware
- backend/server.js — helmet, rate limiting, CORS configuration
- vercel.json — cron + CRON_SECRET usage